

Desenvolvimento de um Sistema Seguro de Autenticação, Comunicação e Gestão de Credenciais em Conformidade com a LGPD

Autor: Pedro (Discente) | Orientador: Prof. Fabiano

RESUMO TÉCNICO-CIENTÍFICO

A transformação digital intensificou o tratamento de dados pessoais em sistemas computacionais, elevando a segurança da informação e a conformidade regulatória a requisitos arquiteturais críticos. Este trabalho apresenta o desenvolvimento, implementação e validação de um ecossistema seguro de autenticação e gestão de credenciais, fundamentado nos princípios de segurança proativa e defesa em profundidade. O sistema desenvolvido mitiga as principais vulnerabilidades associadas a falhas de autenticação através da aplicação estruturada do algoritmo Bcrypt com fator de custo parametrizado em $C = 12$ associado a salts únicos pseudoaleatórios por usuário, impossibilitando ataques de dicionário e rainbow tables locais. Como camada secundária obrigatória, implementou-se um fluxo funcional de autenticação multifator (2FA) baseado em algoritmo temporizado. Mecanismos adaptativos de controle de tentativas (Rate Limiting) impõem um bloqueio temporal imperativo após a quinta falha consecutiva, neutralizando ataques automatizados de força bruta. Para a recuperação de credenciais, foi concebido um subsistema efêmero baseado em tokens criptográficos de alta entropia gerados por PRNG seguro, dotados de expiração de 15 minutos e expurgo imediato pós-uso. A proteção de dados em trânsito é garantida pela imposição estrita do protocolo TLS/HTTPS com bloqueio de tráfego não seguro, enquanto dados sensíveis em repouso são cifrados simetricamente com o algoritmo Advanced Encryption Standard no modo Galois/Counter Mode (AES-256-GCM), mantendo as chaves mestres isoladas em ambiente externo. O alinhamento com a Lei Geral de Proteção de Dados (LGPD) foi operacionalizado através da arquitetura de minimização de dados, registro auditável e imutável de consentimentos (data e versão) e rotas exclusivas para atendimento aos direitos do titular, englobando portabilidade e exclusão definitiva. Testes funcionais de caixa branca e logs detalhados de auditoria comprovaram a resiliência e a eficácia das salvaguardas implementadas na preservação da confidencialidade e integridade dos ativos de informação.

Palavras-chave: Autenticação Criptográfica. Defesa em Profundidade. AES-256-GCM. Lei Geral de Proteção de Dados. Auditoria de Logs.

1. Justificativas Técnicas e Arquitetura do Sistema

O ecossistema foi projetado de forma modular para isolar responsabilidades e assegurar conformidade estrita com o roteiro de avaliação do Projeto Integrador.

1.1 Gestão de Credenciais e Autenticação Multifator (Entrega 2)

O armazenamento de senhas textuais em texto claro constitui uma severa violação de segurança. Para tanto, o sistema utiliza uma função de derivação de chaves baseada em **Bcrypt**. Ao contrário de funções de hash comuns (como MD5 ou SHA-256), o Bcrypt é intencionalmente lento (CPU-bound) e incorpora um salt pseudoaleatório de 128 bits exclusivo para cada usuário. Definir o custo computacional em 12 garante que o cálculo consuma

aproximadamente 250ms, o que é imperceptível para o usuário comum, mas torna financeiramente inviável ataques de força bruta ou dicionário em larga escala.

A proteção contra ataques automatizados online opera por meio de um contador adaptativo. Ao atingir o limite de 5 tentativas inválidas consecutivas, o sistema atualiza o atributo `lockUntil` no banco de dados, bloqueando a conta por uma janela de 15 minutos. O fluxo de login é dividido em duas fases síncronas obrigatórias: a validação bem-sucedida do hash da senha abre permissão exclusiva para a submissão do token TOTP de 6 dígitos de segundo fator (2FA), impedindo o sequestro de sessão mesmo diante de senhas comprometidas.

1.2 Mecanismo Seguro de Recuperação de Senhas (Entrega 3)

A recuperação de contas dispensa perguntas secretas previsíveis e adota tokens dinâmicos de segurança gerados pelo módulo criptográfico nativo através do método `crypto.randomBytes(32)`. O token gerado possui 256 bits de entropia, impossibilitando ataques de predição estatística. O ciclo de vida do token é efêmero, limitado a 15 minutos. Em estrita conformidade com as diretrizes do OWASP, assim que o token é submetido e validado, o registro correspondente é destruído imediatamente da memória (invalidação pós-uso), neutralizando tentativas de reutilização de tokens interceptados.

1.3 Comunicação Criptografada e Dados em Repouso (Entrega 4)

Para garantir a confidencialidade em trânsito, o sistema impede conexões HTTP inseguras por meio de um middleware de infraestrutura que valida o tráfego TLS/HTTPS, descartando de forma proativa pacotes não cifrados para evitar interceptações Man-in-the-Middle (MitM). Para a proteção em repouso, dados qualificáveis como sensíveis pela LGPD (ex: CPF) são submetidos ao algoritmo simétrico **AES-256-GCM**. O modo GCM adiciona autenticidade à cifragem ao gerar uma tag de integridade matemática (Auth Tag). No ato da leitura, se o registro tiver sido adulterado diretamente no banco de dados, a decifração falha automaticamente.

2. Matriz de Ativos, Riscos e Contramedidas (Requisitos 6.6, 6.7 e 6.8)

ID	Ativo Afetado	Ameaça / Vulnerabilidade	Impacto	Contramedida Implementada
R01	BD de Usuários	Ataques de Dicionário Offline ou Rainbow Tables se o banco vazar.	Crítico	Uso do Bcrypt (Custo 12) com geração automática de Salt único por registro.
R02	API de Autenticação	Ataques de Força Bruta online automatizados simulando logins.	Alto	Implementação de Rate Limit com bloqueio imperativo da conta por 15 minutos após 5 erros.
R03	Tokens de Acesso	Sequestro de fluxo ou reuso de tokens de redefinição de senha antigos.	Alto	Tokens gerados via <code>crypto.randomBytes(32)</code> , expiração em 15 min e invalidação pós-uso imediata .
R04	Canal de Rede	Interceptação de dados sensíveis em trânsito (Ataque Man-in-the-Middle).	Crítico	Imposição estrita de tráfego criptografado via TLS/HTTPS com rejeição ativa de conexões HTTP puras.
R05	Armazenamento		Crítico	

ID	Ativo Afetado	Ameaça / Vulnerabilidade	Impacto	Contramedida Implementada
		Acesso direto ao banco de dados expondo documentos de identificação.		Cifragem simétrica de campos em repouso com algoritmo AES-256-GCM e chaves em variáveis externas.

3. Mapeamento de Conformidade com a LGPD (Requisitos 4.1 a 4.11)

Em obediência à Lei 13.709/2018, o sistema adota o princípio de *Data Minimization*, limitando a coleta ao mínimo necessário para a execução da finalidade de autenticação.

- **Listagem e Finalidade (Req 4.1 e 4.2):** O E-mail é coletado sob a base legal de Execução de Contrato (identificação primária); as senhas e tokens 2FA para autenticação de segurança; o CPF é criptografado e guardado para validação cadastral restrita.
- **Gestão de Consentimento (Req 4.4 a 4.7):** O sistema registra de forma indelével no banco o timestamp exato, e-mail e a versão do Termo de Privacidade aceito pelo usuário, permitindo rotas para revogação a qualquer momento.
- **Direitos do Titular (Req 4.8 a 4.11):** Disponibilização de endpoints dedicados para consulta transparente de dados, exportação estruturada (Portabilidade em JSON) e exclusão definitiva dos registros das tabelas (Direito ao Esquecimento).

4. Referências Bibliográficas (Requisitos 6.11 e 6.12)

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. **ABNT NBR ISO/IEC 27002:2022:** Segurança da informação, segurança cibernética e proteção da privacidade — Controles de segurança da informação. Rio de Janeiro: ABNT, 2022.

BARKER, E. **NIST Special Publication 800-131A Revision 2:** Transitions: Recommendation for Transitioning the Use of Cryptographic Algorithms and Key Lengths. National Institute of Standards and Technology, Gaithersburg, MD, 2019.

BRASIL. **Lei nº 13.709, de 14 de agosto de 2018.** Lei Geral de Proteção de Dados Pessoais (LGPD). Brasília, DF: Diário Oficial da União, 2018.

OWASP. **Top 10:2021 – The Critical Security Risks for Web Applications.** Open Web Application Security Project, 2021. Disponível em: <https://owasp.org/Top10/>.